Bosch-Norm

BOSCH

N51M M27

2019-05-14

Attachment 2: User documentation for the IT-Security questionnaire

Table of Contents

1 General notes 2
1.1 Scope 2
1.2 Purpose 2
1.3 Definition of IT-device 2
1.4 File name and versioning 2
1.5 Storage location 2
2 Using the IT-Security questionnaire 3
2.1 Application of the IT-Security questionnaire 3
2.2 Role definition 3
2.2.1 Process for MAE procurement 3
2.2.2 Process for IT-devices procurement 4
2.3 When is the IT-Security questionnaire used? 5
2.4 Sub-process A - Creation of an MAE performance specifications 6
2.5 Sub-process B - Evaluation of the MAE offers and the Bosch-Norm filled by the supplier 6
2.6 Sub-process C - Ordering an MAE according to offer 6
2.7 Sub-process D - Preliminary inspection of the MAE at the supplier 6
2.8 Sub-process E - Delivery of the MAE-order and start-up 6
2.9 Sub-process F - Acceptance of the MAE 6
3 Questions in the IT-Security questionnaire 7
3.1 Overview of questionnaire tabs 7
3.2 The self-assessment in the tab '1. Supplier Information' 7
3.3 The tab '2. Proof' and '3. Part-A Planned IT devices' 8
3.3.1 Answering the questions 8
3.4 Part-A - Planned IT-devices 9
3.5 Part-B - Installed IT-devices 10
3.5.1 Machine network and security-related parts of the machine hardware 11
4 Table of Figures 11
5 Glossary 12

FEO1IZ 2020-01-08 NormMaster

1 General notes

1.1 Scope

The IT-Security questionnaire helps in creating a uniform basis for the valuation for IT-devices used in manufacturing. It especially supports the analysis and comparison of new IT-devices and MAE within the framework of the procurement process.

Furthermore, there is an option to compare the IT-Security questionnaires and to use the IT-device, which fulfils the most requirements of the IT-Security.

1.2 Purpose

IT-devices and MAE with the best IT-Security properties should be preferred during procurement. Inventory of the IT-devices and planning of the network infrastructure.

1.3 Definition of IT-device

IT-device are IT-Systems (Supporting Assets), used by the user to process information (Primary Assets), e.g., IC, IPC, HMI, Robot Controller, BV, Notebooks, Manufacturing-PCs, smartphones and tablets (see CD04602).

The term IT-devices indicates, e.g.:

- The IT-device has been, e.g., assigned an IP address.
- The IT-device is, e.g., reachable through a network.
- The IT-device processes data, which can be exchanged through an accessible data interface (e.g., Bluetooth, Ethernet, mobile bulk storage such as USB-stick, SD-card or CD/DVD-drive, serial interface etc.).
  Examples: computers, controls, active display panels, cameras, robot controls, process controls, welding controls, power screwdrivers etc.

1.4 File name and versioning

The IT-Security questionnaire should be named according to the following convention:

Name [of the project]_inquiring operating unit [GB]_Date [Year][Month][Day]_Version[V.0.0].file extension.

The main versions should be described as follows:

- Version V.1.0 indicates the time after placement of order
- Version V.2.0 indicates the time after project closure.

Examples:

- HDEV10_PS_20190228_V.1.0.xlsx = During order placement
- HDEV10_PS_20190628_V.2.0.xlsx = During project closure

1.5 Storage location

Once the project has been finished, the completed IT security questionnaire must be stored in the following SharePoint:

SharePoint: **2018_Purchasing_Guideline**

Select here the folder corresponding to the division.

FEO1IZ 2020-01-08 NormMaster

2 Using the IT-Security questionnaire

2.1 Application of the IT-Security questionnaire

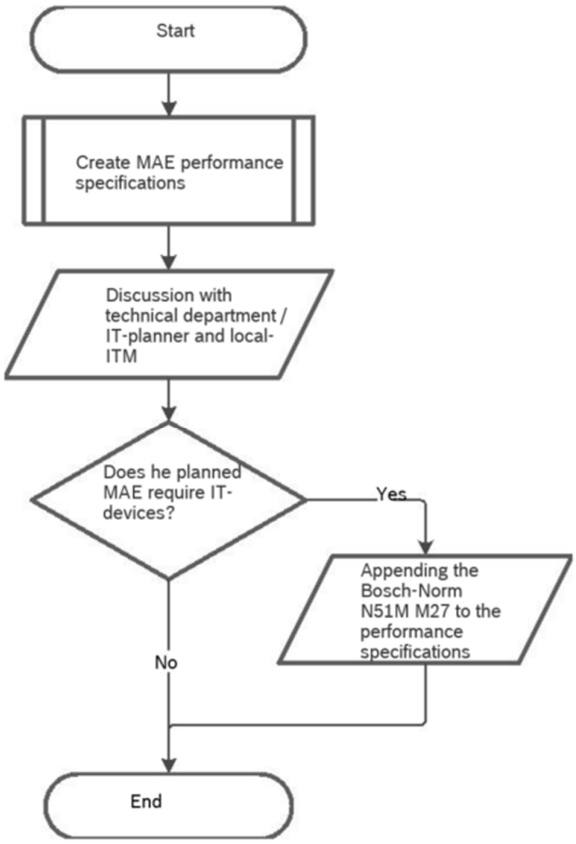
2.2 Role definition

IT-Planner, Local-ITM, technical department and plant management, see Rules of Procedure CD04602.

2.2.1 Process for MAE procurement

Process visualization for using the IT-Security questionnaire.

Table 1 Process for MAE procurement

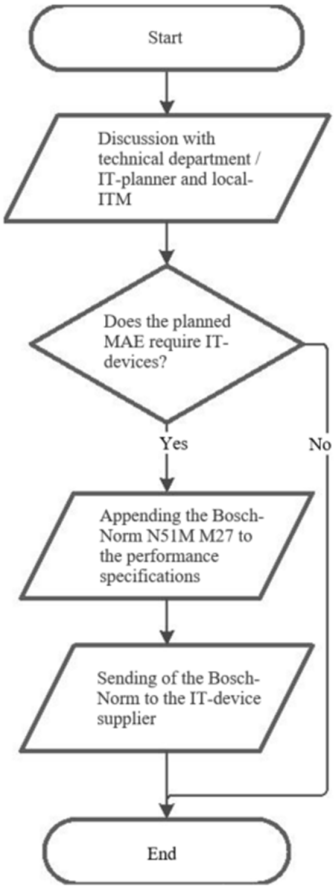
RASIC	Process	Documents
R: Technical department & Purchasing **C**: Local-ITM or IT-Planner **I**: Plant management **A**: Plant management		Performance specifications template

FEO1IZ 2020-01-08 NormMaster

2.2.2 Process for IT-devices procurement

Process visualization for using the IT-Security questionnaire in the procurement of project-related IT-devices.

Table 2 Process for IT-devices procurement

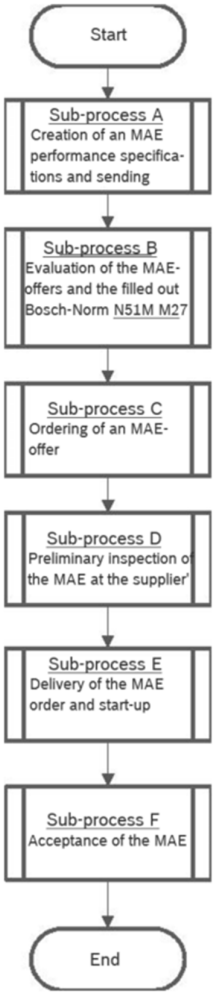
RASIC	Process	Documents
R: Technical department and Purchasing **C:** Local-ITM or IT-Planner **I:** Plant management **A:** Plant management		

FEO1IZ 2020-01-08 NormMaster

2.3 When is the IT-Security questionnaire used?

The following process sequence depicts the sub-processes that are applied in the **MAE**-procurement.

Table 3 Sub-processes in the **MAE**-procurement

RASIC	Process	Activity
R: Technical department & Purchasing **C:** Local-ITM or IT-Planner **I:** Plant management **A:** Plant management		Appendix of the Bosch-Norm N51M M27
R: Technical department & Purchasing **C:** Local-ITM or IT-Planner		Creation of comparison matrix & evaluation of the questionnaire
R: Purchasing		If required, send back supplier information
R: Technical department & Purchasing **C:** Local-ITM or IT-Planner		Countercheck of supplier feedback & delivery state
R: Local-ITM **C:** Technical department & Purchasing		Network planning, if required, ACL clearing & handover of Bosch-Norm with IPs
R: Technical department & Purchasing **C:** Local-ITM or IT-Planner		Check supplier information during acceptance

FEO1IZ 2020-01-08 NormMaster

2.4 Sub-process A - Creation of an MAE performance specifications

If the Bosch-Norm has to be used according to chapter 2.2.1, then it should be sent along as an appendix to the MAE performance specifications.

2.5 Sub-process B - Evaluation of the MAE offers and the Bosch-Norm filled by the supplier

During the offer creation by the supplier, he has to fill the Bosch-Norm N51M M27 with data relevant to the offer context. The procuring technical department, the purchasing, the local-ITM or the IT-planner have to evaluate the data provided by the supplier. If security-relevant information, the documentation or the promised performance do not correspond to the requirements, then the supplier has to be informed and requested for corrections and if required, be rejected.

2.6 Sub-process C - Ordering an MAE according to offer

If necessary, the change requests w.r.t. service, security, documentation should be formulated in a binding manner while ordering. Send back the evaluated questionnaire to the supplier, versioned and in PDF format.

2.7 Sub-process D - Preliminary inspection of the MAE at the supplier

The questionnaire can be used during the preliminary inspection for checking the used IT-devices. The purchasing technical department and purchasing are responsible. If IT-competency is necessary, then the local-ITM will be included. The documentation and network planning is based on a correctly maintained list of the used IT-devices.

2.8 Sub-process E - Delivery of the MAE-order and start-up

At the time of the delivery, the local-ITM has to provide a list containing the provided host names, IP-address, subnet mask and gateway to the supplier. The local-ITM or the IT-planner has to prepare the network clearings required for the operation. The data should be verified with the supplier and be entered in the CMDB.

2.9 Sub-process F - Acceptance of the MAE

The data for the entry in the CMDB should be provided by the supplier and are relevant for the acceptance.

The compliance has to be checked in cooperation with the technical department and the purchase department. The local-ITM has to be informed and can be support in the verification.

FEO1IZ 2020-01-08 NormMaster

3 Questions in the IT-Security questionnaire

The header data of the project, the division, the plant, the inquiring entity and product has to be maintained once in '1. Supplier Information'.

3.1 Overview of questionnaire tabs

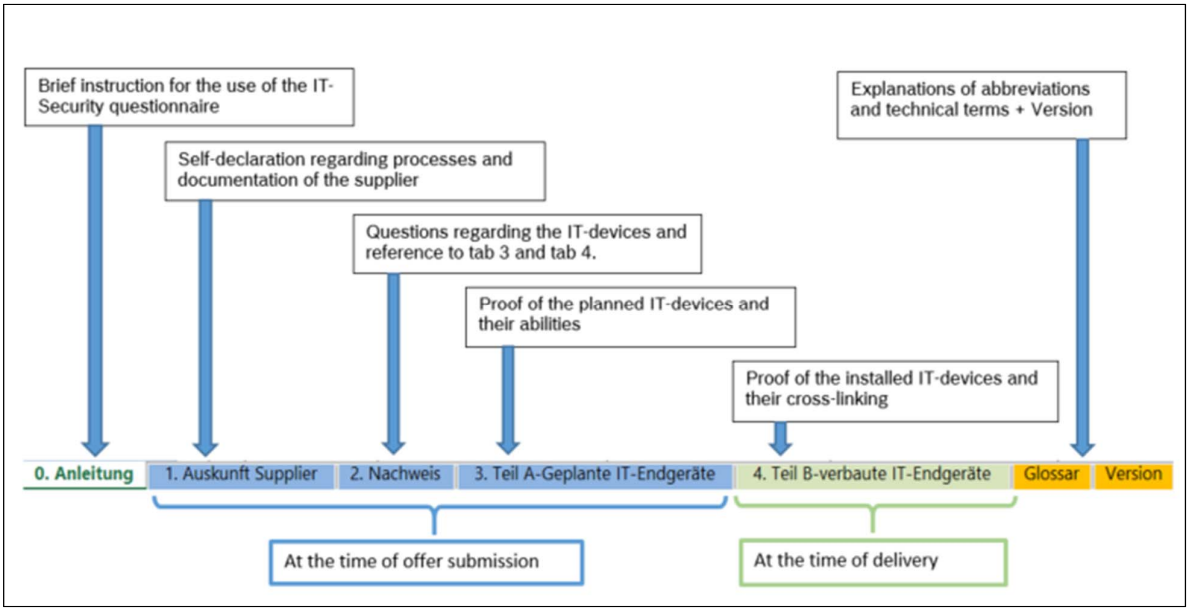


Figure 1 Tab overview

3.2 The self-assessment in the tab '1. Supplier Information'

In the tab '**1. Supplier information**', the supplier has to provide proof for:

- security-relevant processes
- his handling of the hardware to be delivered
- the handling of security updates
- the software available on the IT devices
- the training and maintenance options
- the IT-Security of the organization and contact persons.

Furthermore, there are questions regarding:

- a backup and recovery documentation
- the documentation for supporting an emergency plan
- the use of remote maintenance and
- the options for data processing

The supplier has to answer these questions during the request and, if required, prove the same with corresponding additional documentation. The provided answers should represent the current status at the supplier's location.

FEO1IZ 2020-01-08 NormMaster

3.3 The tab '2. Proof' and '3. Part-A Planned IT devices'

In the tab '2. Proof', the supplier is requested to maintain data relevant for the offer submission. Here, the tab '3. Part-A Planned IT-devices' is referred to in case of individual questions. Data related to the IT-devices is collected in tab 3. The answers in the tab '2. Proof' and in the tab '3. Part-A Planned IT-devices' are collected up to the time of offer.

Furthermore, there are questions whose answers are detailed in the tab '4. Part-B Installed IT-devices'. These answers are expected only at the time of preliminary inspection.

3.3.1 Answering the questions

Drop-down menus 'Please select' are provided for answering the questions; a corresponding answer can also be provided as free text in the field 'Text'.

Please select	
	Text

Figure 2 Drop-down and free text fields

Gray-colored cells are invalid and answers entered there are not relevant.

Answers can also point to other tabs in order to go into detail:

=> Tab 3. Planned IT-devices;
Column **| Manufacturer name | Manufacturer order no. |**

Figure 3 Reference to other tabs

There can be a reference to another tab even due to a selected answer, so that detailed answers can be given there. The column in which the detailing is done and/or, if required, should be taken up through a separate attached document is mentioned between ||. If a document should be appended, then this should be documented in the corresponding column. For example, the note in the column "Remarks": see document in the appendix 'Documentation of the operation.doc'

Please select	**No => Tab 3. Planned IT-devices;** Column **| Remark |**
Please select	**No => Tab 3. Planned IT-devices;** Column **| Remark |**

Figure 4 Reference to other tabs determined by answers

Since both MAE-suppliers and component suppliers use the questionnaire, a strip has been placed before the questions, which shows which questions should be answered by the respective supplier.

FEO1IZ 2020-01-08 NormMaster



Green and white check marks = Questions, which should be answered in the corresponding row.
Here, by the MAE-suppliers and the component suppliers.

Red and cross = the questions with these, do **not** have to be answered by the component manufacturer.

Figure 5 Strip regarding responsibility

3.4 Part-A - Planned IT-devices

In the tab '3. Part-A - Planned IT-devices', the supplier of a component or the MAE-supplier provides details regarding the IT-device. Proof should be provided while submitting a quotation. The purchasing technical department, the purchasing and the local-ITM have to evaluate the details for the operation in the manufacturing.

Detailed questioning can be found in the tab '2. Proof' of the Bosch-Norm.

Fields with the label 'Please select' have drop-down menus that should be used.

	IT-Security questionnaire for MAE			Part-A - Planned IT-devices								
List of IT-devices, which are likely to be used												
No.	In the project	Function / Description	Manufacturer	Manufacturer name	Manufacturer order no.	Availability of replacement units till ...	Security-Level-C as per IEC62443	Operating system	Service pack/ Build	IPvx	Time server	SEP
Example	X	L40 - Installation control	Rexroth	Rexroth IndraLogic L40 04VRS	R911323261	202x	SL-C 1	VX	SP1	IPV4	NTP	yes
1		Text	Text	Text	Text	Text	Please select	Please select	Please select	Please select	Please select	Please select
2		Text	Text	Text	Text	Text	Please select	Please select	Please select	Please select	Please select	Please select

Figure 6 First part of the detailed inquiry

The row **Example** shows an example for filling the row. The rows labeled with the numbers 1-25 can be filled with details about the planned IT-devices. If required, an extension by further rows is possible. The row numbering has to be extended accordingly.

Authentication	Documentation	Comment
For this, refer to the attached description in the appendix of the IT-Security questionnaire.	Service and Support - www.boschrexroth.com	
Text	Text	Text

Figure 7 Second part of the detailed inquiry

FEO1IZ 2020-01-08 NormMaster

3.5 Part-B - Installed IT-devices

The IT-devices installed for each MAE are listed in this table. Proof should be provided during the preliminary inspection of the MAE. For this, it is possible to choose from the planned IT-devices and thereby proof can be furnished for each MAE.

	IT-Security questionnaire for MAE		Part B - Installed IT-devices in the MAE				
			IT-device				
No.	Classification criterion	Name / Description of the machine	Description of IPC, HMI, IC	Serial number	Safety comp.	Network connections	Networking
Example	Line 1, Station 20	Dispensing housing covers	mPad	xxxx.xxxx.xxx	No	LAN	only reachable from Bosch network
Example	Line 1, Station 20	Dispensing housing covers	VPB40	xxxx.xxxx.xxx	No	LAN	internal machine network and reachable from the Bosch network
1	Text	Text	Please select	Text	Please select	Please select	Please select
2	Text	Text	Please select	Text	Please select	Please select	Please select

Figure 8 First part of proof for IT-devices for each machine

The row **Example** shows an example of how an MAE and the included IT-devices can be added.
The corresponding questions are available in the tab '2. Proof'.

The blue fields with the label 'Please select' refer to the table in the tab '3. Part-A - Planned IT-devices' of the column |Function / Description|.

The IT-devices that can be selected come from the list of planned IT-devices.

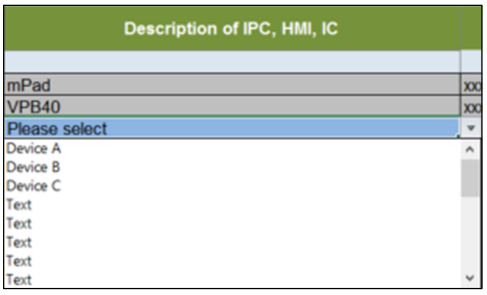


Figure 9 Drop-down selection of planned devices

The allocation of the planned IT-devices to an MAE is described in the column 'Classification criterion'.
Here in the example, Line 1, Station 20 for the station 'Dispensing housing covers'.

In each row, the classification criterion is newly allocated to an MAE. A new criterion has to be described in case of new MAE. A classification criterion contains at least one IT-device.

Network connections	Networking	MAC address	Configuration ports	Communication ports	Server connection
LAN	only reachable from Bosch network				
LAN	internal machine network and reachable from the Bosch network	00:00:00:00:00:00		1065	Server connection to the MES
Please select	Please select	Text	Text	Text	Text
Please select	Please select	Text	Text	Text	Text
Please select	Please select	Text	Text	Text	Text

Figure 10 Second part of the IT-devices proof for each machine

The green area indicates the area to be maintained by the supplier.

Classification criterion	Name / Description of the machine	Description of IPC, HMI, IC	....

Figure 11 Area for proof for each MAE by supplier

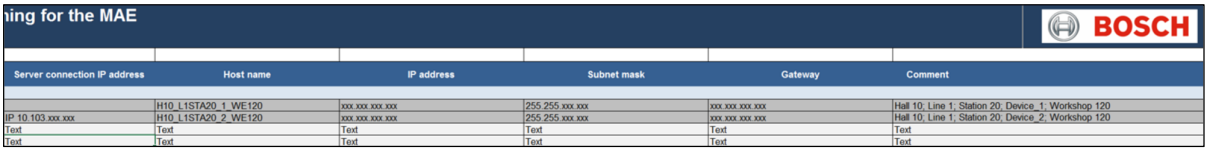
The blue area indicates the area to be maintained/planned by the local-ITM:

Server connection IP address	Host name	IP address	....

Figure 12 Area for proof for each MAE by the local-ITM

FEO1IZ 2020-01-08 NormMaster

The following section has to be planned for each MAE by the local-ITM. During the MAE delivery, the supplier uses this information in order to set up the network in the MAE.



ing for the MAE

Server connection IP address	Host name	IP address	Subnet mask	Gateway	Comment
	H10_L1STA20_1_WE120	xxx xxx xxx xxx	255.255.xxx.xxx	xxx xxx xxx xxx	Hall 10; Line 1; Station 20; Device_1; Workshop 120
IP 10.103.xxx.xxx	H10_L1STA20_2_WE120	xxx xxx xxx xxx	255.255.xxx.xxx	xxx xxx xxx xxx	Hall 10; Line 1; Station 20; Device_2; Workshop 120
Text	Text	Text	Text	Text	Text
Text	Text	Text	Text	Text	Text

Figure 13 Third part of proof for IT-devices for each machine

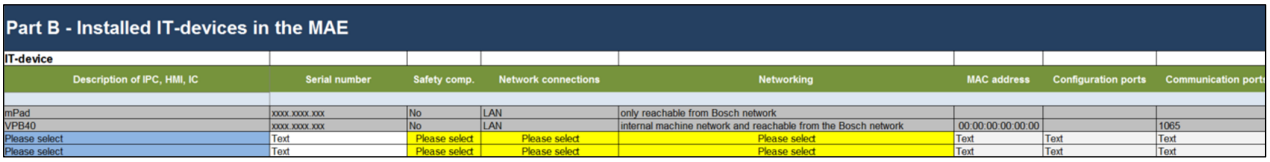
3.5.1 Machine network and security-related parts of the machine hardware

In order to record the network, which is created by the machine, the supplier is requested to prove the same for each MAE.

This way, we differentiate whether the installed IT-device is:

- internal machine network
- internal machine network and reachable from the Bosch network
- reachable only from the Bosch network

Furthermore it is asked, whether the installed IT-device fulfils a safety function. This is made possible through a simple confirmation with yes or no in the column |Safety-comp.|.



Part B - Installed IT-devices in the MAE

IT-device							
Description of IPC, HMI, IC	Serial number	Safety comp.	Network connections	Networking	MAC address	Configuration ports	Communication ports
mPad	xxxx xxxx xxx	No	LAN	only reachable from Bosch network			
VPB40	xxxx xxxx xxx	No	LAN	internal machine network and reachable from the Bosch network	00:00:00:00:00:00		1065
Please select	Text	Please select	Please select	Please select	Text	Text	Text
Please select	Text	Please select	Please select	Please select	Text	Text	Text

Figure 14 Proof for the IT-device function with the network

FEO1IZ 2020-01-08 NormMaster

4 Table of Figures

Figure 1 Tab overview 7
Figure 2 Drop-down and free text fields 8
Figure 3 Reference to other tabs 8
Figure 4 Reference to other tabs determined by answers 8
Figure 5 Strip regarding responsibility 9
Figure 6 First part of the detailed inquiry 9
Figure 7 Second part of the detailed inquiry 9
Figure 8 First part of proof for IT-devices for each machine 10
Figure 9 Drop-down selection of planned devices 10
Figure 10 Second part of the IT-devices proof for each machine 10
Figure 11 Area for proof for each MAE by supplier 10
Figure 12 Area for proof for each MAE by the local-ITM 10
Figure 13 Third part of proof for IT-devices for each machine 11
Figure 14 Proof for the IT-device function with the network 11

5 Glossary

Purchasing	refers to a technical Purchase department in the plant or as centralized service, which is responsible for the manufacturing area (e.g., GS/MAE (previously CP), TME, ...)
Safety-Function	refers to the part of security of a system, which depends on the correct functioning of the safety-related systems and other risk-reducing measures
MAE	Machines and equipment

FEO1IZ 2020-01-08 NormMaster